



[INSTITUTION NAME / LOGO]

Institute Governance, Information Security, and Quality Compliance Policy

An Integrated ISO/IEC 27001:2022 · NAAC · IQAC Aligned Governance Framework

Document Title:	Institute Governance, Information Security & Quality Compliance Policy
Version:	1.0
Effective Date:	January 2026
Review Cycle:	Annual
Approved By:	Governing Body
Prepared By:	Internal Quality Assurance Cell (IQAC)
Standards Referenced:	ISO/IEC 27001:2022, NAAC SSR/IQAC Guidelines, DPDP Principles
Classification:	Internal – Accreditation & Audit Evidence

This document constitutes the governing policy manual for institutional governance, information security management, student data privacy, and quality assurance. It is maintained by IQAC and serves as documented evidence for NAAC accreditation, ISO/IEC 27001 alignment, statutory audits, and institutional risk assessment.

1. Purpose & Scope

This Policy establishes the Institution's integrated framework for governance, information security, academic quality, and regulatory compliance, in alignment with ISO/IEC 27001:2022, NAAC accreditation norms, and IQAC guidelines. It reflects institutional commitment to transparent governance, safeguarding of information assets, protection of student and staff data, and a culture of continuous quality improvement. The Policy applies to all students, faculty, administrative staff, contractors, and third-party service providers, and covers all information systems (ERP, portals, examination and financial systems), academic processes, and physical infrastructure of the Institution. Compliance is mandatory for all stakeholders and is monitored through periodic internal and external audits.

2. Governance Framework (Key Rules)

ID	Policy Statement	Compliance Requirement	Risk of Non-Compliance
GOV-001	Documented strategic plan reviewed annually by Governing Body.	Annual review minutes retained.	Loss of institutional direction.
GOV-002	Defined roles, responsibilities and delegation of authority.	Approved organogram on file.	Accountability gaps.
GOV-003	Statutory and regulatory compliance register maintained.	Register updated quarterly.	Legal / regulatory penalties.
GOV-004	Governing Body and Academic Council meet per statute.	Minutes and attendance records.	Governance failure, audit flag.
GOV-005	Grievance redressal mechanism for staff and students.	Logged and resolved cases.	Stakeholder dissatisfaction.
GOV-006	Financial governance with budget approval workflow.	Approved budgets, audit reports.	Financial mismanagement.
GOV-007	Conflict-of-interest disclosure for decision-makers.	Annual disclosure forms.	Integrity / reputational risk.
GOV-008	Policy documents reviewed and version-controlled annually.	Version log maintained.	Outdated / non-compliant practice.
GOV-009	Committee-based decision-making (IQAC, Academic, Finance).	Committee charters and minutes.	Unstructured decision-making.
GOV-010	Risk management integrated into strategic planning.	Risk register reviewed annually.	Unmanaged institutional risk.

3. Information Security Controls (ISO/IEC 27001 Aligned – Representative Set)

ID	Objective / Policy Statement	Evidence Required	Risk
ISC-01 Access Control	Least-privilege, role-based access to all systems.	Access control matrix, logs.	High
ISC-02 Password Mgmt	Complex passwords, mandatory periodic reset, MFA.	Password policy, MFA config.	High
ISC-03 User Provisioning	Formal approval before account creation.	Provisioning request forms.	Medium
ISC-04 De-Provisioning	Immediate access revocation on exit/role change.	Exit checklist, revocation log.	High
ISC-05 Audit Logging	System and access logs retained & reviewed.	Log samples, review reports.	Medium
ISC-06 Backup Mgmt	Scheduled backups with periodic restore testing.	Backup schedule, test reports.	High
ISC-07 Incident Reporting	Defined incident reporting & response workflow.	Incident register.	High
ISC-08 Security Monitoring	Continuous monitoring of critical systems.	Monitoring dashboards/alerts.	Medium
ISC-09 Asset Management	Inventory of IT assets with ownership.	Asset register.	Medium
ISC-10 Data Classification	Data labelled by sensitivity (Public/Internal/Confidential).	Classification policy.	High
ISC-11 Malware Protection	Endpoint protection on all institutional devices.	AV deployment report.	Medium
ISC-12 Network Security	Firewalls, segmentation, and VPN for remote links.	Network diagram, configs.	High
ISC-13 Remote Access	Secure, authenticated remote access only.	VPN/remote access logs.	Medium
ISC-14 Change Management	Approved change requests for system modifications.	Change request records.	Medium
ISC-15 Business Continuity	Documented BCP/DR plan, tested annually.	BCP document, test logs.	High

4. Student Data Privacy & Academic Governance (Representative Controls)

ID	Description	Compliance Requirement
PRV-01	Student academic records secured with restricted access.	Access logs, role mapping.
PRV-02	Examination data encrypted in transit and at rest.	Encryption configuration proof.
PRV-03	Attendance data collected only for stated academic purpose.	Purpose limitation statement.
PRV-04	Personal information shared with third parties only on consent.	Signed consent records.
PRV-05	Defined data retention periods for student records.	Retention schedule document.
PRV-06	Secure disposal of records after retention period.	Disposal / destruction log.
ACD-01	Curriculum designed with defined Course & Program Outcomes.	CO-PO mapping documents.
ACD-02	Examinations conducted under documented security protocol.	Exam security SOP.
ACD-03	Academic integrity policy covering plagiarism/malpractice.	Plagiarism reports, policy.
ACD-04	Periodic internal academic audits by IQAC.	Audit reports, action logs.

5. Risk Assessment Matrix

Impact	Likelihood	Risk Level
High	High	Critical
High	Medium	High
Medium	Medium	Medium
Low	Low	Low

6. Compliance Assessment Methodology

Each control is assessed as **Fully Compliant (100%)**, **Partially Compliant (50%)**, or **Non-Compliant (0%)**, based on documented evidence. The overall institutional compliance percentage is calculated as the average score across all applicable controls in Sections 3–10 of the full policy manual, weighted by risk level. Non-compliant items are logged in the Non-Compliance Register with root-cause analysis and a time-bound Corrective Action Plan, verified for closure by IQAC before the next review cycle.

7. Policy Review & Approval

This Policy shall be reviewed annually (or upon significant regulatory/organisational change) by IQAC in consultation with the Information Security Committee, and formally approved by the Governing Body. All revisions are version-controlled, communicated to stakeholders, and archived for audit reference. This condensed manual summarises the complete 15-section policy framework, appendices (Control Summary, Compliance Checklist, Audit Questionnaire) and full control set maintained in the master document held by IQAC.

Prepared By Internal Quality Assurance Cell (IQAC)	Reviewed By Information Security Committee	Approved By Governing Body
--	--	--------------------------------------